

Esquema Nacional de Seguridad



El [Real Decreto 311/2022 de 3 de mayo](#), actualiza el Esquema Nacional de Seguridad (ENS), en el marco del paquete de actuaciones urgentes adoptado el 25 de mayo de 2022, para reforzar las capacidades de defensa frente a las ciberamenazas sobre el sector público y las entidades colaboradoras que suministran tecnologías y servicios al mismo.

La actualización de este documento estaba contemplada en el Plan Nacional de Ciberseguridad, dotado con 1.000 millones de euros, una de las normativas necesarias para aplicar también el Real Decreto de Ciberseguridad 5G, convalidado por el Congreso de los Diputados y parte de las reformas pactadas con la Comisión Europea.

El nuevo Esquema Nacional de Seguridad, que ha experimentado una evolución continua desde su primer desarrollo en 2010, establece la política de seguridad para la protección adecuada de la información tratada y los servicios prestados a través de un planteamiento común de principios básicos, requisitos mínimos, medidas de protección y mecanismos de conformidad y monitorización para la administración pública, así como para los proveedores tecnológicos del sector privado que colaboran con la administración.

El ENS se mantendrá actualizado de manera permanente, desarrollándose y perfeccionándose a lo largo del tiempo, en paralelo al avance de los servicios prestados por las entidades del sector público, la evolución tecnológica, la aparición o consolidación de nuevos estándares internacionales sobre seguridad y auditoría y los riesgos a los que estén expuestos los sistemas de información concernidos.

Novedades

- Adecuación del ENS al nuevo marco normativo y al contexto estratégico existente para garantizar la seguridad en la Administración Digital.
- El ajuste de los requisitos a necesidades, colectivos de entidades y ámbitos tecnológicos para una aplicación más eficaz y eficiente.

- Actualización de los principios básicos y las medidas de seguridad para facilitar una mejor respuesta a las nuevas tendencias y necesidades de ciberseguridad.

El nuevo texto persigue garantizar la protección de los sistemas de información en las entidades de su ámbito de aplicación, reduciendo vulnerabilidades y promoviendo la vigilancia continua, estableciendo a su vez mecanismos de respuesta y medidas de seguridad óptimas, dentro del marco jurídico, tecnológico, estratégico y de ciberamenazas actuales.

Como nuevas medidas de seguridad, se han incluido las relativas a servicios en la nube, interconexión de sistemas, protección de la cadena de suministro, medios alternativos, vigilancia y otros dispositivos conectados a la red.

Objetivos

- Alinear el ENS con el marco normativo y el contexto estratégico existente para garantizar la seguridad en la administración digital en beneficio de la ciberseguridad y de los derechos de la ciudadanía, así como actualizar las referencias al marco legal vigente conforme a la Estrategia Nacional de Ciberseguridad y el Plan Nacional de Ciberseguridad.
- Introducir la capacidad de ajustar los requisitos del ENS para garantizar su adaptación a la realidad de ciertos colectivos o tipos de sistemas, atendiendo a la semejanza que presentan una multiplicidad de entidades o servicios en cuanto a los riesgos en el ENS del concepto de «perfil de cumplimiento específico» que, aprobado por el Centro Criptológico Nacional, permita alcanzar una adaptación del ENS más eficaz y eficiente, racionalizando los recursos requeridos sin menoscabo de la protección perseguida y exigible.
- Facilitar una mejor respuesta a las tendencias en ciberseguridad, reducir vulnerabilidades y promover la vigilancia continua mediante la revisión de los principios básicos, de los requisitos mínimos y de las medidas de seguridad.
- Crear las condiciones necesarias de seguridad en el uso de los medios electrónicos, a través de medidas para garantizar la seguridad de los sistemas, los datos, las comunicaciones, y los servicios electrónicos, que permita el ejercicio de derechos y el cumplimiento de deberes a través de estos medios.

Informe del estado de la seguridad

El Real Decreto recoge que la Comisión Sectorial de Administración Electrónica, órgano técnico presidido por el Secretario General de Administración Digital del Ministerio para la Transformación Digital y de la Función Pública para la cooperación de la Administración General del Estado con las comunidades autónomas y entidades locales en materia de administración digital, recopilará la información de las principales variables de la ciberseguridad.

Los resultados del informe serán utilizados por las autoridades competentes que impulsarán las medidas oportunas que faciliten la mejora continua del estado de la seguridad.

El Centro Criptológico Nacional (CCN), del Centro Nacional de Inteligencia (CNI) adscrito al Ministerio de Defensa, articulará la respuesta a los incidentes de seguridad de entidades del sector público.

Respecto a las entidades del sector privado, notificarán la respuesta que han realizado ante incidentes de seguridad al Instituto Nacional de Ciberseguridad de España (INCIBE).

Por otra parte, la Secretaría de Estado de Digitalización e Inteligencia Artificial, será la encargada de aprobar las instrucciones técnicas de seguridad de obligado cumplimiento.

La aprobación de este Real Decreto se vincula con la ejecución del Plan de Digitalización de las Administraciones Públicas 2021-2025, uno de los instrumentos principales para el cumplimiento del Plan de Recuperación, Transformación y Resiliencia y su Componente 11 denominado «Modernización de las Administraciones Públicas», así como para el desarrollo de las inversiones y reformas previstas en la agenda España Digital 2026.

El Plan de Digitalización contempla expresamente, entre sus reformas, la actualización del Esquema Nacional de Seguridad con el fin de hacer evolucionar la política de seguridad de todas las entidades del sector público español, considerando las regulaciones de la Unión Europea dirigidas a incrementar el nivel de ciberseguridad de los sistemas de información.

Así, complementa esta reforma la constitución del Centro de Operaciones de Ciberseguridad de la Administración General del Estado y sus Organismos Públicos (COCS), previsto en la Medida 9 del Plan de Digitalización de las Administraciones Públicas 2021 – 2025, servicio que servirá de referencia para las demás administraciones públicas y contribuirá a mejorar su capacidad de respuesta ante eventuales ataques.

Medidas de seguridad en el tratamiento de datos personales

Con relación a las medidas de seguridad del ENS en el tratamiento de datos personales, la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, ordenó en su disposición adicional primera que dichas medidas de seguridad se implanten en caso de tratamiento de datos personales para evitar su pérdida, alteración o acceso no autorizado, adaptando los criterios de determinación del riesgo en el tratamiento de los datos a lo establecido en el artículo 32 del Reglamento (UE) 2016/679, del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas, en lo que respecta al

tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos).

De otra parte, la disposición adicional primera también prescribe la implantación de las medidas de seguridad del ENS a las entidades del sector público y a las del sector privado que colaboren con estas en la prestación de servicios públicos que involucren el tratamiento de datos personales. Por último, y en el mismo sentido, la Ley Orgánica 7/2021, de 26 de mayo, de protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y de ejecución de sanciones penales, ha establecido en su artículo 37 la obligación de aplicar las medidas del ENS a los tratamientos de datos personales por parte de las autoridades públicas competentes.

En este sentido, el Ministerio se compromete al cumplimiento de su obligación de secreto con respecto a los datos de carácter personal y al deber de tratarlos con confidencialidad. A estos efectos, adoptará las medidas necesarias para evitar su alteración, pérdida, tratamiento o acceso no autorizado, como queda referido en [su política de privacidad y protección de datos](#).